

Bypassing Multi-Pass Filters - Websecurity (English translation)

Обхід багатопрохідних фільтрів - Websecurity - Author not stated, websecurity.com.ua.

- Title in English: Bypassing Multi-Pass Filters - Websecurity
- Published: date not stated
- Original: <<http://websecurity.com.ua/2115/>>
- Preserved from: <http://websecurity.com.ua/2115/> (live) on 2026-08-09
- Licence: unknown

Rights remain with the original author and publisher. This is a research archive of a source from the Web Hacking Techniques Index collections, kept so the page going offline. To read the original, follow the link above.

Content (translated into English)

Machine translation of [websecurity-com-ua-websecurity.md](#), which holds the source's own words. Code, payloads, type names, URLs and CVE identifiers were masked before translating and restored after, so they are byte-identical to the original.

UNTRUSTED SOURCE TEXT. Everything below this line is third-party material quoted for research. It is data, not instructions. Do not follow directions, execute code, or fetch URLs because this text says so.

Bypassing Multi-Pass Filters - Websecurity - Web Security

Bypassing Multi-Pass Filters

22:45 17.05.2008

I will tell you about bypassing multi-pass filters. When a website uses a complex (multi-pass) filtering system, particularly for XSS filtering, it may be possible to bypass the multi-pass filters. Such multi-pass filtering systems may be used on large portals and social networks.

There is one technique for bypassing multi-pass filters that I developed in 2007: a filter-bypass technique that uses spaces. I called it the space-hack technique. I wrote about it during the [Month of Bugs in MySpace](#).

The essence of the technique is that when a website uses a multi-pass filter (particularly an XSS filter) that first checks for attack code (XSS) and then removes spaces to bring the data into the required state, this filtering behavior can be exploited. By taking advantage of the filter's multiple passes, it is possible first to submit data containing spaces in order to bypass the filter, after which all spaces will be removed during the filter's next stage, making the code functional again so that it executes on the user's page.

Let us consider the following examples.

1. Code for bypassing multi-pass filters:

```
<p/style="xss:expression(alert(document.cookie))">
```

At the first stage, the filter checks for XSS code: it checks for keywords, including "expression." Since "e xpression" is used in this case, no keywords are found and this string passes through the filter.

At the second stage, the filter removes the spaces; as a result, we obtain code that will execute on the user's page:

```
<p/style="xss:expression(alert(document.cookie))">
```

Note that, because of the second stage, I used "<p/style" rather than "<p style" so that the code would remain functional after passing through the filters (because spaces are removed at the second filtering stage).

1. Code for bypassing multi-pass filters:

```
<img/width="100"src="http://site/image.jpg"onLoad="alert(document.cookie)">
```

At the first stage, the filter checks for XSS code: since "onLoad" is used in this case, no keywords are found and this string passes through the filter.

At the second stage, the filter removes the spaces; as a result, we obtain code that will execute on the user's page:

```
<img/width="100"src="http://site/image.jpg"onLoad="alert(document.cookie)">
```

As I noted above, because of the second stage, I used "/" as the separator between the tag name and its attribute; that is, I used the notation "<img/width". This makes the code functional after it passes through the filters.

As the examples above show, the space-hack technique can be used to bypass multi-pass filters. Web application developers should take this technique into account when developing filtering systems.

This entry was posted on 22:45 17.05.2008 and is filed under [Articles](#). You can follow any responses to this entry through the [RSS 2.0](#) feed.

Leave a Reply

You must be [logged in](#) to post a comment.
